



Assignment on Dvwa,Zap,Nessus,Nikto

Submitted By:

Name : Joyanta Kumer Sarker

Module No: 5

Batch No: 7

Submitted To:

Name : Navid Bin Mahamud

Associate manager

(software security & Risks)

Brac Bank PLC

Submission Date: 04.01.2026

Table of Contents

Loccaly Run DVWA :	3
Task 1-Zap scan on DVWA:.....	4-5
Zap scan Report:	5-15
Task 2- Nessus scan on Metasploitable 2.....	15-20
Task 3-Nikto Scan on DVMA.....	20-23

Loccaly Run DVWA :

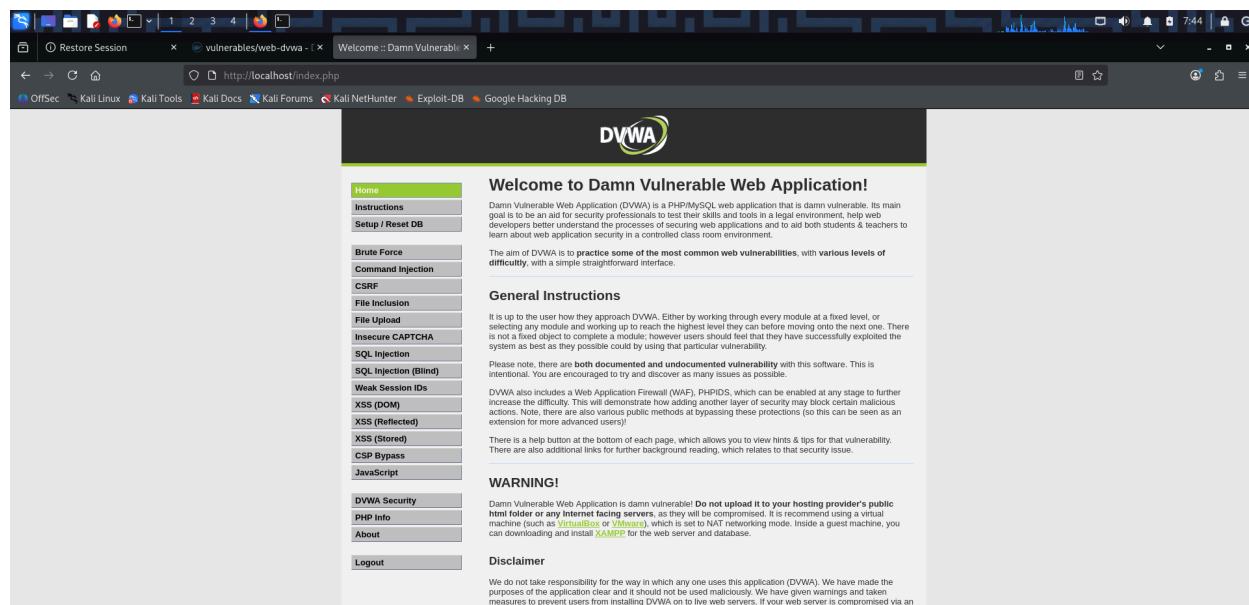
```

(kali@kali)~$ sudo docker pull vulnerabilities/web-dvwa
[sudo] password for kali:
Using default tag: latest
latest: Pulling from vulnerabilities/web-dvwa
Digest: sha256:dae203f1164a80977d4eb0079ade295f426da68a92b40e3b181f137daa7
Status: Image is up to date for vulnerabilities/web-dvwa:latest
docker.io/vulnerables/web-dvwa:latest

(kali@kali)~$ sudo docker run --rm -it -p 80:80 vulnerabilities/web-dvwa

[+] Starting mysql ...
[+] Starting apache
[....] Starting Apache httpd web server: apache2AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 172.17.0.2. Set the 'ServerName' directive globally to suppress this message
...
/var/log/apache2/access.log ==
/var/log/apache2/error.log ==
[Sun Jan 04 13:43:21.03251 2026] [mpm_prefork:notice] [pid 316] AH00163: Apache/2.4.25 (Debian) configured - resuming normal operations
[Sun Jan 04 13:43:21.03353 2026] [core:notice] [pid 316] AH00094: Command line: '/usr/sbin/apache2'
...
/var/log/apache2/other_vhosts_access.log ==
/var/log/apache2/access.log ==
172.17.0.1 - - [04/Jan/2026:13:43:40 +0000] "GET /login.php HTTP/1.1" 200 1192 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
172.17.0.1 - - [04/Jan/2026:13:43:55 +0000] "POST /login.php HTTP/1.1" 302 337 "http://localhost/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
172.17.0.1 - - [04/Jan/2026:13:43:55 +0000] "GET /setup.php HTTP/1.1" 200 2064 "http://localhost/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
172.17.0.1 - - [04/Jan/2026:13:44:00 +0000] "POST /setup.php HTTP/1.1" 302 337 "http://localhost/setup.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
172.17.0.1 - - [04/Jan/2026:13:44:00 +0000] "GET /setup.php HTTP/1.1" 200 2180 "http://localhost/setup.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
...
/var/log/apache2/error.log ==
[Sun Jan 04 13:44:00.545482 2026] [error] [pid 321] [client 172.17.0.1:44478] PHP Notice: Constant DVWA_WEB_PAGE_TO_ROOT already defined in /var/www/html/dvwa/includes/DBMS/MySQL.php on line 9, referer: http://localhost/setup.php
...
/var/log/apache2/access.log ==
172.17.0.1 - - [04/Jan/2026:13:44:06 +0000] "GET /login.php HTTP/1.1" 200 1049 "http://localhost/setup.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
172.17.0.1 - - [04/Jan/2026:13:44:17 +0000] "POST /login.php HTTP/1.1" 302 337 "http://localhost/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
172.17.0.1 - - [04/Jan/2026:13:44:17 +0000] "GET /index.php HTTP/1.1" 200 3836 "http://localhost/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
172.17.0.1 - - [04/Jan/2026:13:54:50 +0000] "GET / HTTP/1.1" 302 479 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"
172.17.0.1 - - [04/Jan/2026:13:54:50 +0000] "GET /index.php/ HTTP/1.1" 302 478 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"
172.17.0.1 - - [04/Jan/2026:13:54:50 +0000] "GET /index.php/RoxIEL8B.prly HTTP/1.1" 302 478 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"
172.17.0.1 - - [04/Jan/2026:13:54:50 +0000] "GET /index.php/RoxIEL8B.jsa HTTP/1.1" 302 478 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"
172.17.0.1 - - [04/Jan/2026:13:54:50 +0000] "GET /index.php/RoxIEL8B.shtml HTTP/1.1" 302 478 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"
172.17.0.1 - - [04/Jan/2026:13:54:50 +0000] "GET /index.php/RoxIEL8B.maridom HTTP/1.1" 302 478 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"
172.17.0.1 - - [04/Jan/2026:13:54:50 +0000] "GET /index.php/RoxIEL8B.ml HTTP/1.1" 302 478 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"
172.17.0.1 - - [04/Jan/2026:13:54:50 +0000] "GET /index.php/RoxIEL8B.cs HTTP/1.1" 302 478 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"
172.17.0.1 - - [04/Jan/2026:13:54:50 +0000] "GET /index.php/RoxIEL8B.cs HTTP/1.1" 302 478 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"
...

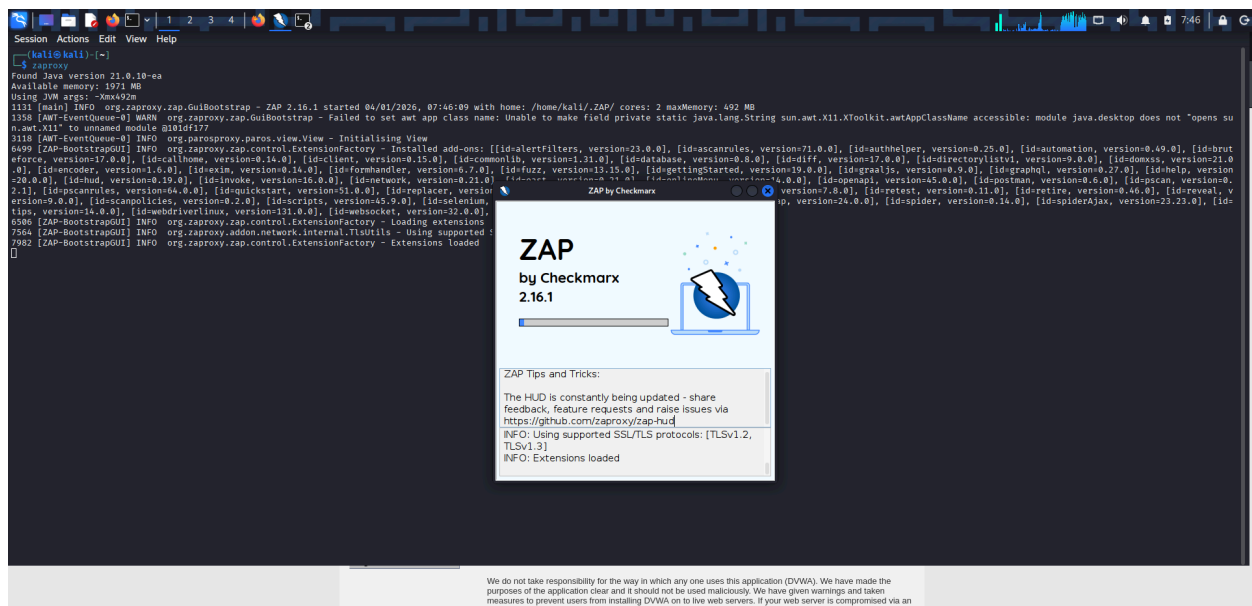
```



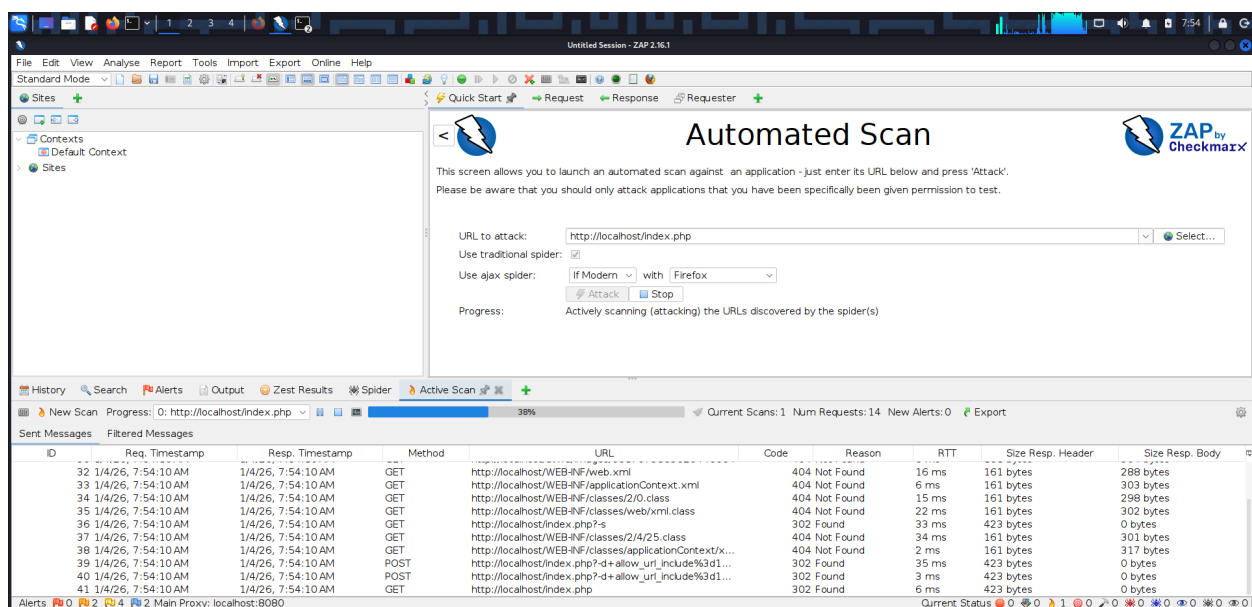
DVWA is successfully running on the local server using localhost, which confirms that the web server and required services are properly configured. The DVWA interface (login/dashboard page) is visible, indicating that the application

and database setup have been completed correctly and the environment is ready for safe vulnerability testing.

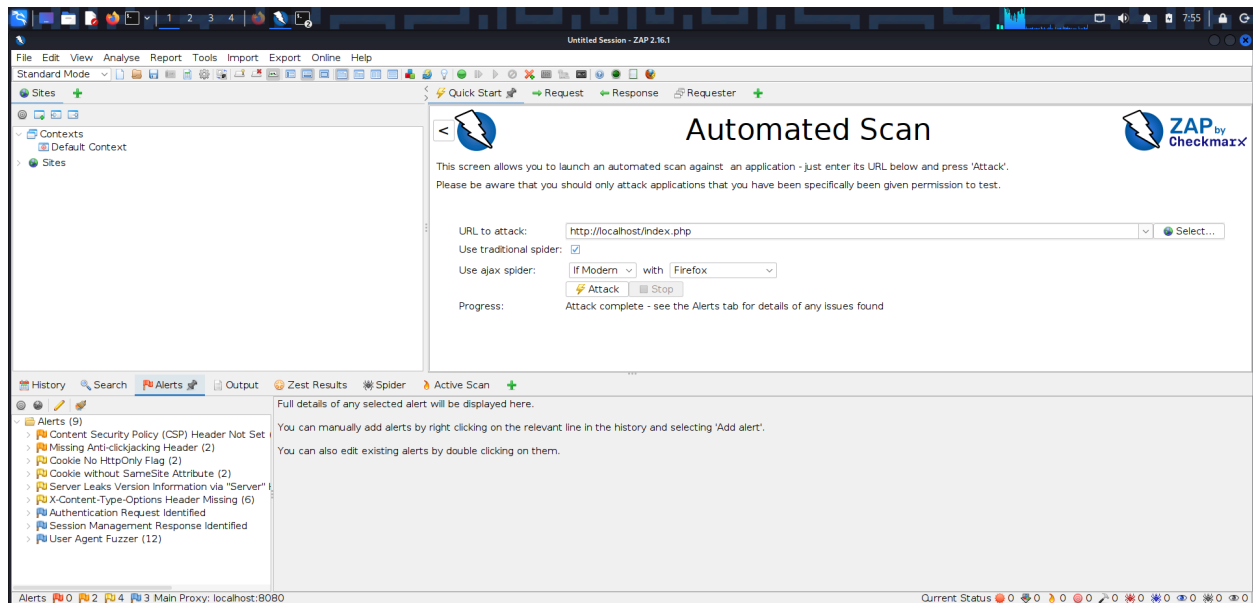
Task 1-Zap scan on DVWA:



Start zap



Give the Url of DVMA



Found 9 alerts.

The first image shows that the DVWA website has been successfully loaded and proxied through OWASP ZAP, allowing the tool to intercept and analyze the application traffic. The second image shows the active or automated scan process in ZAP, where the tool is crawling the DVWA application and testing different inputs to identify possible security vulnerabilities. The third image displays the scan results, where multiple alerts are listed with different risk levels, indicating the presence of various security issues in the DVWA web application.

Zap scan Report:



ZAP by Checkmarx Scanning Report

Site: <http://localhost>

Generated on Sun, 4 Jan 2026 08:19:52

ZAP Version: 2.16.1

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	2
Low	4
Informational	3

Alerts

Name	Risk Level	Number of Instances
Content Security Policy (CSP) Header Not Set	Medium	3
Missing Anti-clickjacking Header	Medium	2
Cookie No HttpOnly Flag	Low	2
Cookie without SameSite Attribute	Low	2
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	9
X-Content-Type-Options Header Missing	Low	6
Authentication Request Identified	Informational	1
Session Management Response Identified	Informational	1
User Agent Fuzzer	Informational	12

Alert Detail

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost/index.php

Method	GET
Attack	
Evidence	
Other Info	
URL	http://localhost/login.php
Method	GET
Attack	
Evidence	
Other Info	
URL	http://localhost/sitemap.xml
Method	GET
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/Security/CSP/Introducing_Content_Security_Policy https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038
Medium	Missing Anti-clickjacking Header
Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	http://localhost/index.php
Method	GET
Attack	
Evidence	
Other Info	
URL	http://localhost/login.php
Method	GET
Attack	
Evidence	
Other Info	

Instances	2
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Low	Cookie No HttpOnly Flag
Description	A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible.
URL	http://localhost/index.php
Method	GET
Attack	
Evidence	Set-Cookie: PHPSESSID
Other Info	
URL	http://localhost/index.php
Method	GET
Attack	
Evidence	Set-Cookie: security
Other Info	
Instances	2
Solution	Ensure that the HttpOnly flag is set for all cookies.
Reference	https://owasp.org/www-community/HttpOnly
CWE Id	1004
WASC Id	13
Plugin Id	10010

Low	Cookie without SameSite Attribute
Description	A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.
URL	http://localhost/index.php
Method	GET
Attack	
Evidence	Set-Cookie: PHPSESSID
Other Info	
URL	http://localhost/index.php
Method	GET

Attack	
Evidence	Set-Cookie: security
Other Info	
Instances	2
Solution	Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.
Reference	https://tools.ietf.org/html/draft-ietf-httpbis-cookie-same-site
CWE Id	1275
WASC Id	13
Plugin Id	10054

Low	Server Leaks Version Information via "Server" HTTP Response Header Field
Description	The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.
URL	http://localhost/
Method	GET
Attack	
Evidence	Apache/2.4.25 (Debian)
Other Info	
URL	http://localhost/dvwa/css/login.css
Method	GET
Attack	
Evidence	Apache/2.4.25 (Debian)
Other Info	
URL	http://localhost/dvwa/images/login_logo.png
Method	GET
Attack	
Evidence	Apache/2.4.25 (Debian)
Other Info	
URL	http://localhost/dvwa/images/RandomStorm.png
Method	GET
Attack	
Evidence	Apache/2.4.25 (Debian)
Other Info	
URL	http://localhost/index.php
Method	GET
Attack	
Evidence	Apache/2.4.25 (Debian)
Other Info	

URL	http://localhost/login.php
Method	GET
Attack	
Evidence	Apache/2.4.25 (Debian)
Other Info	
URL	http://localhost/robots.txt
Method	GET
Attack	
Evidence	Apache/2.4.25 (Debian)
Other Info	
URL	http://localhost/sitemap.xml
Method	GET
Attack	
Evidence	Apache/2.4.25 (Debian)
Other Info	
URL	http://localhost/login.php
Method	POST
Attack	
Evidence	Apache/2.4.25 (Debian)
Other Info	
Instances	9
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.
Reference	https://httpd.apache.org/docs/current/mod/core.html#servertokens https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10036

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://localhost/dvwa/css/login.css
Method	GET
Attack	
Evidence	
Other	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages

Info	away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost/dvwa/images/login_logo.png
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost/dvwa/images/RandomStorm.png
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost/index.php
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost/login.php
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost/robots.txt
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	6
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer

Reference	/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Authentication Request Identified
---------------	-----------------------------------

Description	The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.
URL	http://localhost/login.php
Method	POST
Attack	
Evidence	password
Other Info	userParam=Login userValue=Login passwordParam=password referer=http://localhost/login.php csrfToken=user_token
Instances	1
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/
CWE Id	
WASC Id	
Plugin Id	10111

Informational	Session Management Response Identified
---------------	--

Description	The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
URL	http://localhost/index.php
Method	GET
Attack	
Evidence	a8srmdbtm3iul6h0ggnp0tb8q7
Other Info	cookie:PHPSESSID
Instances	1
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id
CWE Id	
WASC Id	
Plugin Id	10112

Informational	User Agent Fuzzer
---------------	-------------------

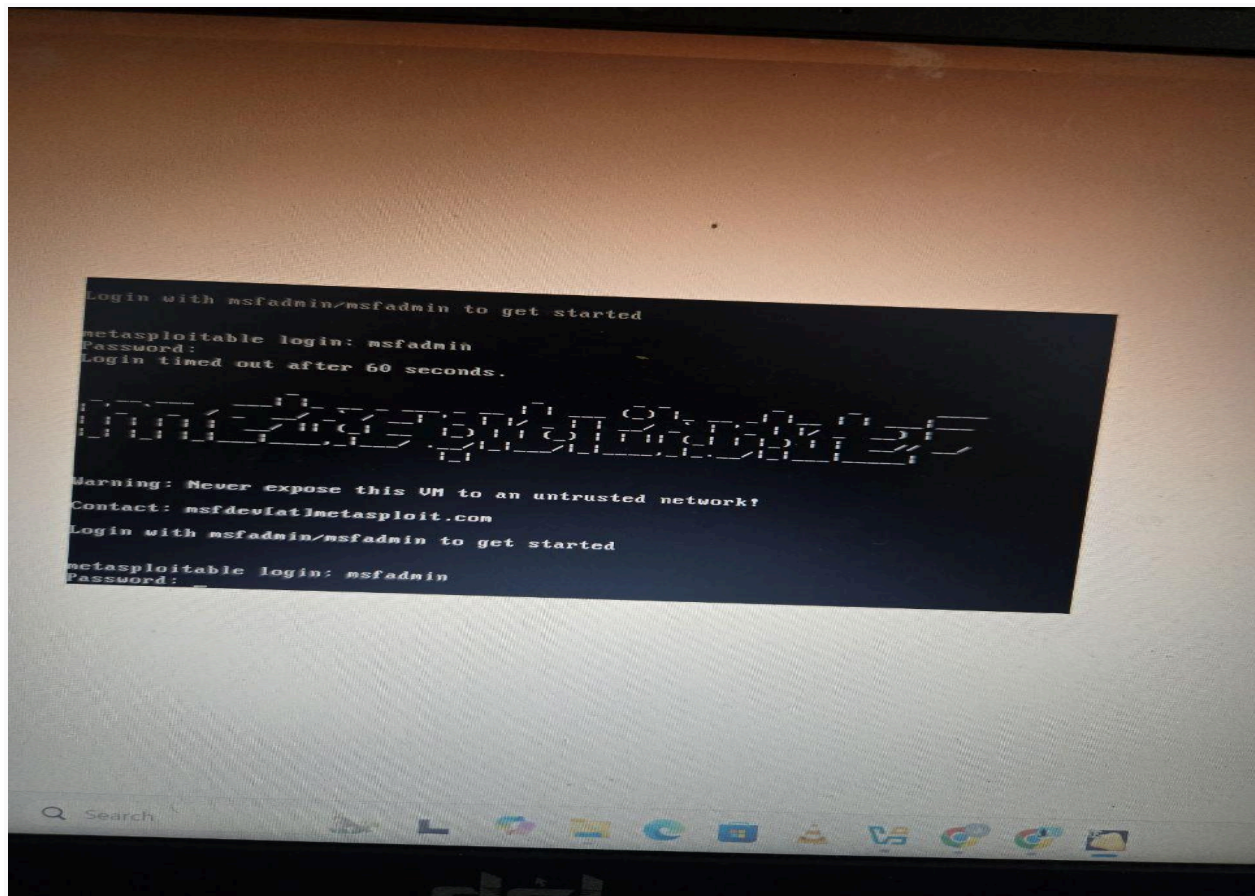
Description	Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.
URL	http://localhost/index.php
Method	GET

Attack	Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)
Evidence	
Other Info	
URL	http://localhost/index.php
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0)
Evidence	
Other Info	
URL	http://localhost/index.php
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
URL	http://localhost/index.php
Method	GET
Attack	Mozilla/5.0 (Windows NT 10.0; Trident/7.0; rv:11.0) like Gecko
Evidence	
Other Info	
URL	http://localhost/index.php
Method	GET
Attack	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/75.0.3739.0 Safari/537.36 Edg/75.0.109.0
Evidence	
Other Info	
URL	http://localhost/index.php
Method	GET
Attack	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/91.0.4472.124 Safari/537.36
Evidence	
Other Info	
URL	http://localhost/index.php
Method	GET
Attack	Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:93.0) Gecko/20100101 Firefox/91.0
Evidence	
Other Info	
URL	http://localhost/index.php
Method	GET

Attack	Mozilla/5.0 (compatible; Googlebot/2.1; +http://www.google.com/bot.html)
Evidence	
Other Info	
URL	http://localhost/index.php
Method	GET
Attack	Mozilla/5.0 (compatible; Yahoo! Slurp; http://help.yahoo.com/help/us/ysearch/slurp)
Evidence	
Other Info	
URL	http://localhost/index.php
Method	GET
Attack	Mozilla/5.0 (iPhone; CPU iPhone OS 8_0_2 like Mac OS X) AppleWebKit/600.1.4 (KHTML, like Gecko) Version/8.0 Mobile/12A366 Safari/600.1.4
Evidence	
Other Info	
URL	http://localhost/index.php
Method	GET
Attack	Mozilla/5.0 (iPhone; U; CPU iPhone OS 3_0 like Mac OS X; en-us) AppleWebKit/528.18 (KHTML, like Gecko) Version/4.0 Mobile/7A341 Safari/528.16
Evidence	
Other Info	
URL	http://localhost/index.php
Method	GET
Attack	msnbot/1.1 (+http://search.msn.com/msnbot.htm)
Evidence	
Other Info	
Instances	12
Solution	
Reference	https://owasp.org/wstg
CWE Id	
WASC Id	
Plugin Id	10104

The ZAP scan report shows the detailed results of the vulnerability assessment performed on the DVWA web application. The report lists multiple security issues along with their risk levels such as High, Medium, Low, and Informational. Each finding includes a brief description of the vulnerability, the affected URL, and possible recommendations, which helps in understanding the security weaknesses present in the application and how they can be mitigated.

Task 2- Nessus scan on Metasploitable 2



```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:5a:ac:21
          inet addr:10.0.2.3  Bcast:10.0.2.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe5a:ac21/64  Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:28 errors:0 dropped:0 overruns:0 frame:0
          TX packets:89 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:4389 (4.2 KB)  TX bytes:10999 (10.7 KB)
          Base address:0xd020  Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128  Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:147 errors:0 dropped:0 overruns:0 frame:0
          TX packets:147 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:46241 (45.1 KB)  TX bytes:46241 (45.1 KB)
msfadmin@metasploitable:~$
```

In this section Setup metasploitable 2.

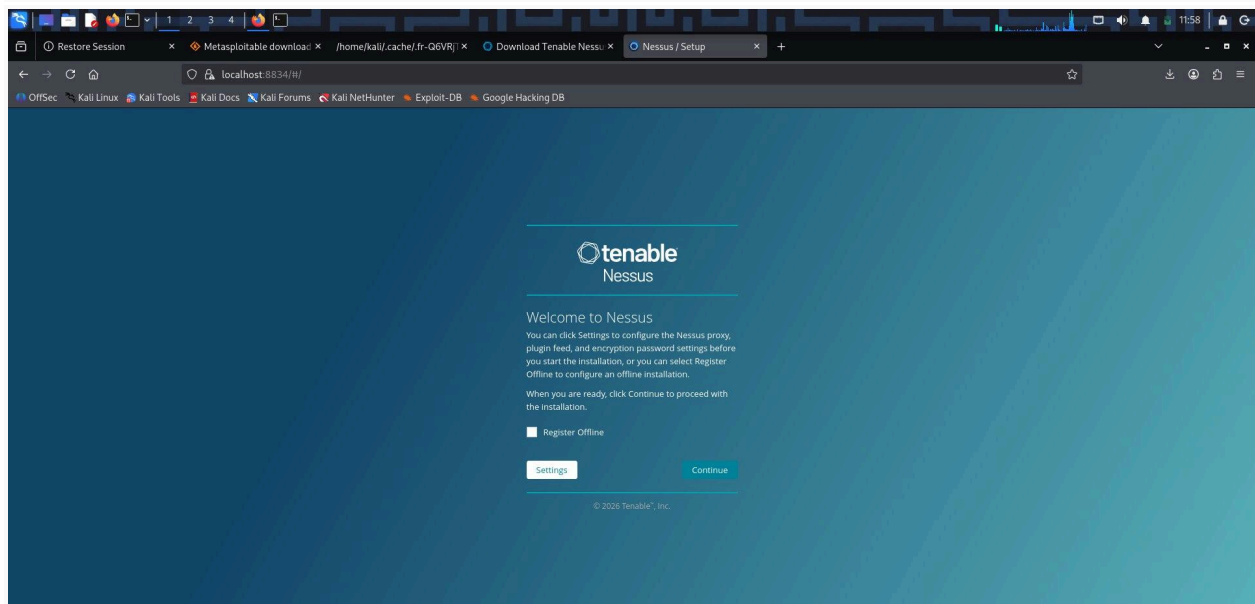

```

Session Actions Edit View Help
RSA : (KAT_Signature) : RNG : (Continuous_RNG_Test) : Pass
Pass
ECDSA : (PCT_Signature) : Pass
ECDSA : (PCT_Signature) : Pass
DSA : (PCT_Signature) : Pass
TLS12_KDF_EXTRACT : (KAT_KDF) : Pass
TLS12_KDF_EXPAND : (KAT_KDF) : Pass
TLS12_PRF : (KAT_KDF) : Pass
PBKDF2 : (KAT_KDF) : Pass
SHA1 : (KAT_KDF) : Pass
SHA256 : (KAT_KDF) : Pass
HKDF : (KAT_KDF) : Pass
SHA384 : (KAT_KDF) : Pass
X963KDF : (KAT_KDF) : Pass
X963KDF : (KAT_KDF) : Pass
HMAC : (DRBG) : Pass
CTR : (DRBG) : Pass
HMAC : (DRBG) : Pass
DH : (KAT_KA) : Pass
ECDH : (KAT_KA) : Pass
RSA_Encrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
INSTALL PASSED
Unpacking Nessus Scanner Core Components...

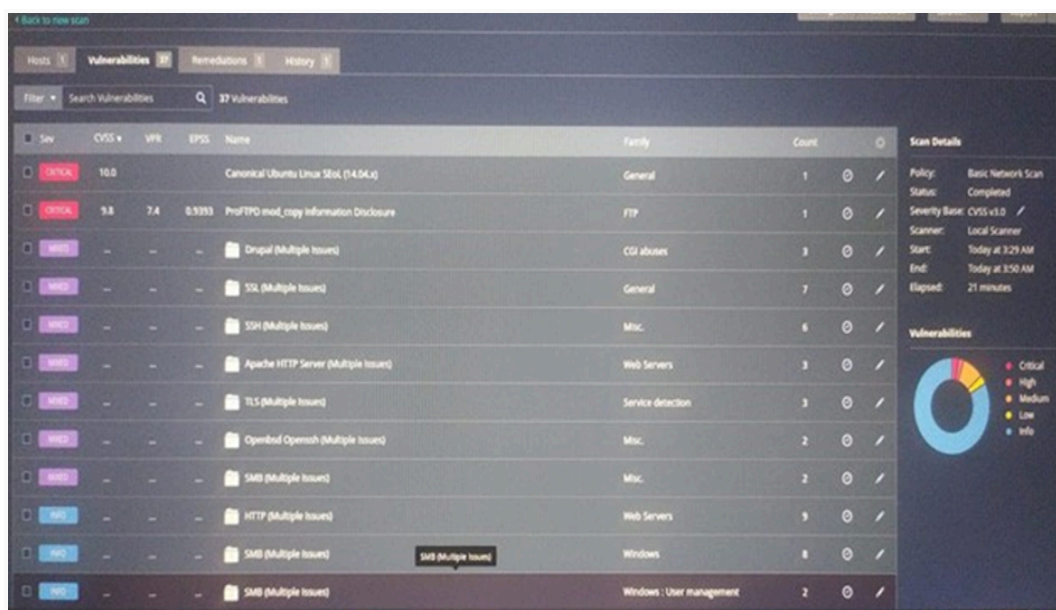
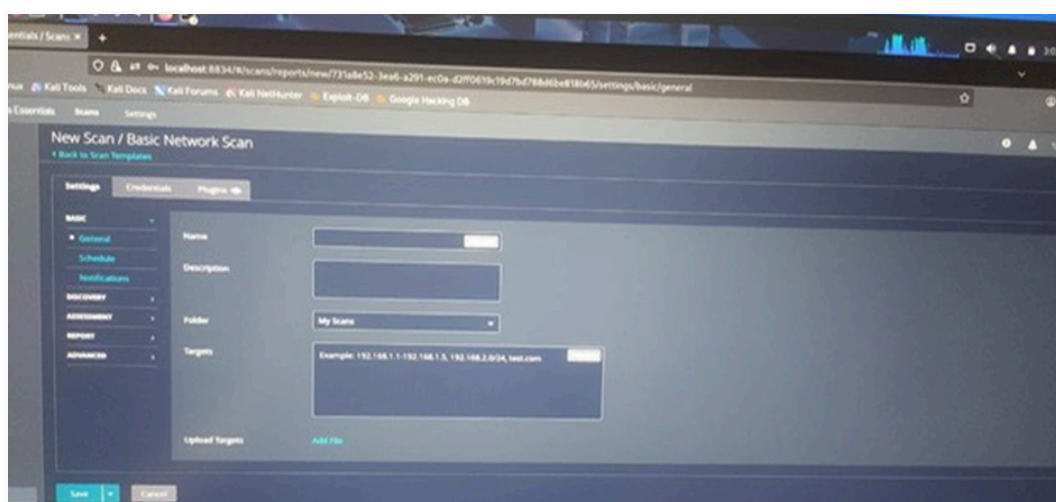
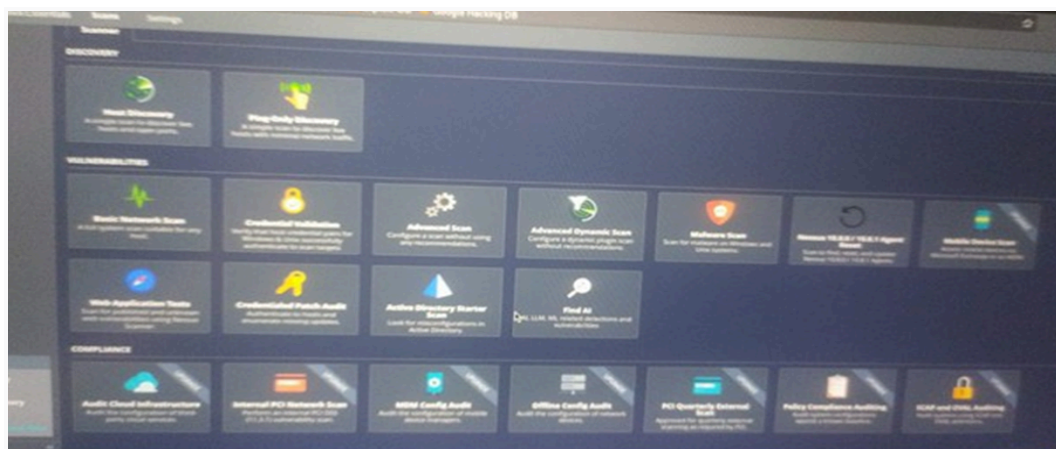
- You can start Nessus Scanner by typing /bin/systemctl start nessusd.service
- Then go to https://NESSUS_HOSTNAME_OR_IP:8834/ to configure your scanner

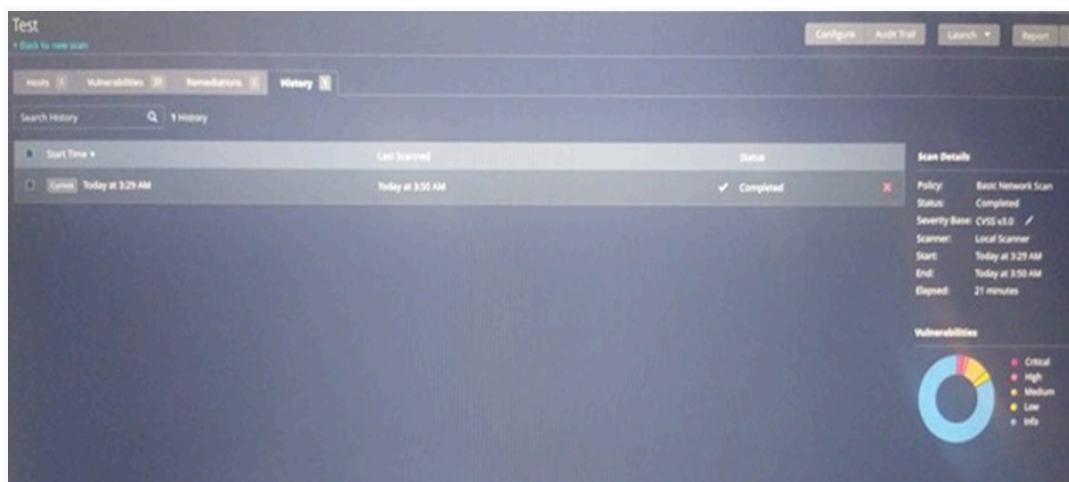
[kali@kali]-(~/Downloads)
$ sudo systemctl start nessusd
[kali@kali]-(~/Downloads)
$ sudo systemctl status nessusd
sudo: systemctl: command not found
[kali@kali]-(~/Downloads)
$ sudo systemctl status nessusd
● nessusd.service - The Nessus Vulnerability Scanner
   Loaded: loaded (/usr/lib/systemd/system/nessusd.service; disabled; preset: disabled)
   Active: active (running) since Mon 2025-01-05 11:49:35 EST; 54s ago
   Invocation: id2897efa9fc445a88869e06bb761da
   Main PID: 7216 (nessus-service)
     Tasks: 17 (limit: 110)
    Memory: 173.5M (peak: 174M)
       CPU: 33.577s
    CGroup: /system.slice/nessusd.service
            └─7216 /opt/nessus/sbin/nessus-service -q

```



Here, Install Nessus.





Title: Vulnerability Assessment Findings from Nessus Scan

Description:

A recent Nessus vulnerability scan identified multiple security weaknesses in the system, including critical, medium, and low-risk issues that could potentially be exploited by attackers.

Severity: CVSS v3.0

Impact:

Critical Vulnerabilities (2): Pose an immediate and serious risk. Exploitation could allow attackers to gain full control of the system.

Medium Vulnerabilities (7): Present moderate risk. Exploitation could cause disruption or partial compromise but is less severe than critical vulnerabilities.

Low Vulnerabilities (Remaining): Do not pose a direct threat but indicate potential weaknesses that may be exploited in the future.

Remediation:

Nessus scan has provided one recommended remediation to address the identified issues. Immediate action is advised for the critical vulnerabilities, followed by mitigation of medium and low-risk issues.

Task 3-Nikto Scan on DVWA

```

(kali@kali)~$ nikto
Nikto v2.5.8

+ ERROR: No host (-host) specified

Options:
-ask+      Whether to ask about submitting updates
            yes Ask about each (default)
            no Don't ask, don't send
            auto Don't ask, just send
-check+    Check if IPv6 is working (connects to ipv6.google.com or value set in nikto.conf)
-cgidirs+  Scan these CGI dirs: "none", "all", or values like "/cgi/" /cgi-a/"
-config+   Use this config file
-display+  Turn on/off display outputs:
            1 Show redirects
            2 Show cookies received
            3 Show all 200/OK responses
            4 Show URLs which require authentication
            0 Debug output
            E Display all HTTP errors
            P Print progress to STDOUT
            S Scrub output of IPs and hostnames
            V Verbose output
-dbcheck+  Check database and other key files for syntax errors
-evasion+  Encoding techniques:
            1 Random URI encoding (non-UTF8)
            2 Directory self-reference (../)
            3 Premature URL ending
            4 Prepend long random string
            5 Fake parameter
            6 TAB as request spacer
            7 Change the case of the URL
            8 Use windows directory separator (\)
            A Use a carriage return (0x0d) as a request spacer
            B Use binary value 0x0b as a request spacer
-followredirects+ Follow 3xx redirects to new location
-format+   Save file (-o) format:
            csv Comma-separated-value
            json JSON Format
            htm HTML Format
            nbe Nessus NBE format
            sql Generic SQL (see docs for schema)
            txt Plain text
            xml XML Format
            (if not specified the format will be taken from the file extension passed to -output)
-help+    This help information
-host+    Target host/URL
-id+      Host authentication to use, format is id:pass or id:pass:realm

We do not take responsibility for the way in which any one uses this application (DVWA). We have made the
purposes of the application clear and it should not be used maliciously. We have given warnings and taken
measures to prevent users from installing DVWA on to live web servers. If your web server is compromised via an
installation of DVWA it is not our responsibility it is the responsibility of the user to take individual and technical

```

```

Session Actions Edit View Help
File Upload
a Authentication Bypass
b Software Identification
c Remote Source Inclusion
d Webservice
e Administrative Console
x Reverse Tuning Options (i.e., include all except specified)
-timeout- Timeout for requests (default 10 seconds)
-Userdb- Load only user databases, not the standard databases
all Disable standard dbs and load only user dbs
tests Disable only db_tests and load udb_tests
-useragent Over-rides the default useragent
-until- Run until the specified time or duration
-url- Target host/URL (alias of -host)
-usecookies Use cookies from responses in future requests
-useproxy Use the proxy defined in nikto.conf, or argument http://server:port
-Version Print plugin and database versions
-vhost- Virtual host (for host header)
-akcode Ignore these HTTP codes as negative responses (always). Format is "302,301".
-A0string Ignore this string in response body content as negative response (always). Can be a regular expression.
* requires a value

(hali@kali) ~
$ nikto -h http://localhost/index.php
- Nikto v2.5.0

+ Target IP: 127.0.0.1
+ Target Hostname: localhost
+ Target Port: 80
+ Start Time: 2026-01-04 08:54:56 (GMT-5)

+ Server: Apache/2.4.25 (Debian)
+ /index.php/: Cookie PHPSESSID created without the httpOnly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /index.php/: Cookie security created without the httpOnly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /index.php/: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /index.php/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Root page /index.php redirects to login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Apache/2.4.25 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ OPTIONS: allowed HTTP Methods: OPTIONS, HEAD, GET, POST
+ 7550 requests: 0 error(s) and 6 item(s) reported on remote host
+ End Time: 2026-01-04 08:55:16 (GMT-5) (20 seconds)

+ 1 host(s) tested

(hali@kali) ~
$

```

The first image shows the Nikto scanning process running against the DVWA web server, where Nikto checks for known vulnerabilities, dangerous files, and server misconfigurations. The second image displays the scan results, highlighting issues such as insecure server settings, outdated components, and potentially risky files found on the DVWA server.

Nikto Scan Report:

1. Cookie Security

- Title: Missing HttpOnly Flag in Cookies
- Description: The cookies on the website are being set without the HttpOnly flag, which prevents client-side scripts from accessing the cookies.
- Severity: Medium
- Impact: Attackers could steal sensitive session data by exploiting client-side vulnerabilities like Cross-Site Scripting (XSS).
- Remediation: Set the HttpOnly flag on all cookies to prevent access by JavaScript. This can be done by modifying the server configuration.

2. Clickjacking Protection

- Title: Missing X-Frame-Options Header
- Description: The X-Frame-Options header is not present in the HTTP response.
- Severity: Medium
- Impact: This vulnerability allows the web page to be embedded within an iframe on malicious sites, which can lead to clickjacking attacks.
- Remediation: Add the X-Frame-Options header with a value of SAMEORIGIN or DENY to prevent the page from being embedded in an iframe.

3. Apache Server Outdated

- Title: Apache Version Outdated
- Description: The Apache server version (2.4.25) is outdated and is not the latest secure version.
- Severity: High
- Impact: Older versions may have known vulnerabilities that can be exploited by attackers.
- Remediation: Update the Apache server to the latest stable version to ensure that known vulnerabilities are patched.

4. Missing Content-Type Header

- Title: Missing Content-Type Header in Response
- Description: The HTTP response does not include the Content-Type header, which could allow the user agent to render the content of the site in a different way.
- Severity: Medium
- Impact: This can cause improper handling of content types, leading to security risks like script execution.
- Remediation: Ensure the Content-Type header is set correctly for all responses.

5. Other Minor Issues

- Title: Directory Traversal and Permissions Issues
- Description: Potential issues with directory listings and permissions could expose sensitive files on the server.
- Severity: Low
- Impact: Information leakage or potential access to sensitive resources.
- Remediation: Disable directory listing and ensure proper file and directory permissions are set.